UNIVERSIDAD PERUANA

CAYETANO HEREDIA



FACULTAD DE CIENCIAS E INGENIERÍA

"ALBERTO CAZORLA TALLERI"

Departamento Académico de Ciencias Exactas - Sección Ingeniería

LABORATORIO 14

CURSO

SISTEMAS OPERATIVOS

INTEGRANTES

- Huancas Bereche, Erick Emilio
- Pellanne Aro, Carlos Alfredo
- Reyes Garcia Alvaro Pablo
- Rivera Garayar, Matias Gabriel
- Romero Chac, Luis Antonio

DOCENTE

Dr. Roberto Eduardo Burga Montañez

GRUPO

SOIF1 - G2

Introducción

Los sistemas operativos constituyen la base sobre la que funcionan aplicaciones, servicios, redes y mecanismos de almacenamiento. Por ello, su seguridad afecta a la integridad de los procesos, al uso adecuado de recursos y a la protección de la información. En una organización, el problema no se limita a impedir ataques externos: también implica controlar privilegios, prevenir errores operativos, mantener la continuidad del servicio y establecer responsabilidades claras.

La presentación formula la pregunta de cómo gestionar la seguridad de la información en una empresa y responde a través de una secuencia conceptual. Primero se definen los elementos del ciberespacio y los objetivos de protección; después se explican amenazas, vulnerabilidades, riesgos y controles; finalmente se describen soluciones concretas relacionadas con aplicaciones, identidades, redes, datos y servicios en la nube.

Tema 1. Seguridad, protección, amenazas y objetivos de seguridad.

La primera parte define el ciberespacio como un entorno digital interconectado en el que intervienen redes, servicios, sistemas, personas, procesos y organizaciones. Su funcionamiento integra componentes como el software, los servicios de internet, las tecnologías de la información y las comunicaciones, el Internet de las Cosas (IoT) y los usuarios. Esta interconexión incrementa las posibilidades de comunicación y de operación, pero también amplía la superficie expuesta a incidentes de seguridad.

La presentación diferencia la ciberdelincuencia de la ciberseguridad. La primera comprende delitos cometidos en internet o con apoyo de tecnologías informáticas. La segunda se orienta a proteger a las personas, organizaciones, sociedad y naciones de riesgos cibernéticos. La finalidad no es declarar imposible todo incidente, sino mantener la exposición al riesgo en un nivel tolerable mediante controles y una gestión adecuada.

En términos organizacionales, la protección exige determinar qué activos son importantes: bases de datos, credenciales, archivos, dispositivos, plataformas de operación y servicios. También demanda reconocer qué partes participan en su uso y cómo podría perjudicarlas una falla. El esquema inicial justifica estudiar la seguridad como una responsabilidad transversal y no como una tarea exclusiva de instalar antivirus o bloquear computadoras.

La idea central del tema es que, a medida que aumentan los servicios y dispositivos conectados, también aumentan las posibilidades de ataque. Por ello, proteger un sistema operativo implica atender simultáneamente a los elementos técnicos, a los procedimientos de la organización y al comportamiento de las personas.

Tema 2. Intentos de acceso no autorizado

Un acceso no autorizado ocurre cuando una persona, proceso o sistema pretende consultar, modificar o utilizar recursos sin los permisos establecidos. Para comprender la gravedad de estos intentos, la presentación introduce la seguridad de la información y su objetivo de preservar la confidencialidad, la integridad y la disponibilidad. La confidencialidad impide que la información llegue a terceros no autorizados; la integridad protege la exactitud y completitud de los datos; la disponibilidad asegura que los recursos puedan utilizarse cuando se necesitan.

El material explica que el Sistema de Gestión de Seguridad de la Información (SGSI) proporciona un mecanismo organizado para identificar, evaluar y tratar riesgos según las necesidades de la empresa. También relaciona la ciberseguridad con la seguridad de internet, la seguridad de la web y la seguridad de las redes. En este enfoque aparecen elementos como la seguridad perimetral, la nube, los extremos, las aplicaciones, los datos y la recuperación ante desastres.

Una vulnerabilidad es la debilidad de un activo o control que una amenaza podría explotar. Puede presentarse en hardware, software, redes, personal, instalaciones o procesos

organizacionales. Entre los ejemplos mostrados se encuentran la ausencia de pruebas, las comunicaciones desprotegidas, la capacitación insuficiente y la falta de revisión de los derechos de acceso. Una amenaza, en cambio, es una causa potencial de un incidente: robo de información, infección de malware, manipulación de datos o uso fraudulento del sistema.
Las diapositivas distinguen además a los agentes de amenaza, que son los individuos o grupos relacionados con la ejecución o el apoyo de un ataque. Comprender sus capacidades, motivaciones e intenciones permite dimensionar mejor el riesgo. La presentación ilustra cómo una amenaza aprovecha una vulnerabilidad específica: por ejemplo, la ausencia de cifrado facilita el robo de información, y la falta de controles sobre los permisos puede conducir a accesos indebidos.
El riesgo para la seguridad de la información se entiende a partir de la probabilidad de ocurrencia y el impacto de las consecuencias. Entre los posibles impactos figuran la filtración de datos, la pérdida de integridad, el deterioro del rendimiento, la interrupción de operaciones y la indisponibilidad de servicios. La gestión de riesgos consiste en establecer criterios, identificarlos, analizarlos, evaluarlos y tratarlos.
Para reducir esa exposición se utilizan controles de seguridad. Según su naturaleza, pueden ser técnicos, legales, administrativos o gerenciales. Según su función, pueden ser preventivos, de detección o correctivos. Los controles adecuados disminuyen vulnerabilidades o la probabilidad de incidentes; algunos también reducen sus consecuencias. La conclusión del tema es que una estrategia eficaz comienza antes de que ocurra un ataque, al reconocer las debilidades y priorizar su tratamiento.

Tema 3. Políticas y mecanismos de seguridad
Las políticas de seguridad establecen criterios de actuación y responsabilidades; los mecanismos son medidas prácticas que permiten cumplirlos. El bloque se centra especialmente en los vectores de ataque, entendidos como los medios utilizados por un agresor para acceder a sistemas o producir un resultado malintencionado. Entre ellos aparecen la suplantación de cuentas, aplicaciones comprometidas, ataques basados en navegador, archivos adjuntos de correo electrónico, puertas abiertas y explotación de vulnerabilidades.
Los ataques internos se originan dentro de la organización y pueden involucrar errores de empleados, uso inadecuado de privilegios, incumplimiento de políticas o actuaciones intencionales. Para mitigarlos, la presentación propone capacitar al personal, establecer comunicación con áreas responsables, analizar comportamientos sospechosos, aplicar prevención de pérdida de datos (DLP) y usar sistemas de gestión de eventos e información de seguridad (SIEM).
Los ataques externos provienen de actores fuera de la organización. El material toma como referencia el Panorama de Amenazas de ENISA 2022 y menciona malware, ransomware, ingeniería social, amenazas contra los datos, denegación de servicio, amenazas a internet, desinformación y ataques a la cadena de suministro. No todos afectan de la misma manera: unos buscan datos, otros persiguen dinero o alteran la disponibilidad, y otros manipulan información.
El malware es software diseñado con intención maliciosa para afectar sistemas, servicios o datos. La presentación menciona virus, gusanos, troyanos, spyware, botnets y ransomware. Su mitigación requiere actualización de sistemas, gestión de vulnerabilidades, capacitación de usuarios, controles de acceso, supervisión de registros, detección de software malicioso e inventarios de activos.
El ransomware constituye una amenaza especialmente relevante porque puede cifrar información y exigir un pago para recuperarla. La preparación demanda copias de seguridad seguras, planes de respuesta ante incidentes, protección de dispositivos finales, controles de acceso, filtrado de correos, conservación de registros y coordinación con equipos especializados. El énfasis debe ponerse también en la capacidad de restaurar información y continuar la

operación.
La ingeniería social explota el comportamiento humano a través de engaños. Incluye phishing, spear phishing, smishing, vishing y suplantación de identidad. La mitigación considera concienciación, verificación de solicitudes y dominios, vigilancia de sitios fraudulentos, análisis de amenazas y revisión de los medios por los que una organización expone su identidad digital.
El documento distingue los ataques deliberados contra los datos de las fugas que pueden derivarse de errores o fallas técnicas. También estudia los ataques de denegación de servicio distribuida (DDoS), destinados a sobrecargar servicios, sistemas o redes e impedir su uso. Frente a ello se recomiendan planes de continuidad, equipos de respuesta, controles de red, actualización de sistemas y seguimiento del tráfico.
Finalmente, la desinformación y la información errónea son tratadas como amenazas capaces de manipular decisiones y perjudicar a personas y organizaciones. Las medidas de mitigación incluyen educación, verificación, comunicación responsable y mecanismos de detección. Este bloque muestra que la seguridad combina tecnología, gobierno organizacional y evaluación constante del entorno.

Tema 4. Validación

El cuarto bloque utiliza el título “Validación”, pero desarrolla un conjunto amplio de medidas destinadas a comprobar y fortalecer la seguridad de aplicaciones y sistemas. La idea inicial es incorporar seguridad desde el diseño, durante el desarrollo y a lo largo del ciclo de vida del software, en lugar de dejarla únicamente para una revisión final. Se destacan los principios de ingeniería de seguridad, la definición de responsabilidades y la integración de riesgos de seguridad en las actividades de desarrollo.
En las aplicaciones orientadas a internet, la presentación menciona controles de autenticación, autorización, cifrado, registro de eventos y comprobación de seguridad. Se explican revisiones de código y pruebas de seguridad en distintas etapas: análisis estático (SAST), composición de software (SCA), análisis dinámico (DAST), pruebas interactivas (IAST) y protección durante la ejecución (RASP). Cada enfoque ayuda a identificar defectos o riesgos desde una perspectiva distinta.
El bloque incorpora la criptografía como herramienta para proteger la confidencialidad, integridad, autenticación y no repudio de la información. El cifrado simétrico emplea una clave compartida y resulta apropiado para proteger grandes volúmenes de datos por su velocidad. El cifrado asimétrico utiliza un par de claves, una pública y otra privada, y resulta útil para autenticación, intercambio seguro de claves y otros procesos criptográficos. Los esquemas híbridos combinan la rapidez del primero con las posibilidades de distribución de claves del segundo.
La gestión de claves es esencial para que la criptografía sea eficaz. El material cubre generación, distribución, almacenamiento, recuperación, archivo, rotación y eliminación de claves. Una clave expuesta o mal administrada puede inutilizar las protecciones incluso si el algoritmo empleado es sólido. Por eso se recomienda mantener controles y procedimientos durante todo el ciclo de vida de las claves.
Otro componente es la gestión de vulnerabilidades técnicas. La presentación propone un proceso continuo compuesto por identificación, evaluación, solución y notificación. También introduce las categorías de gravedad del sistema CVSS: ninguna (0,0), baja (0,1–3,9), media (4,0–6,9), alta (7,0–8,9) y crítica (9,0–10,0). Esta clasificación permite priorizar el tratamiento de fallos según su severidad.
La gestión de configuraciones y cambios busca mantener sistemas bajo control cuando se instalan aplicaciones, modifican servicios o actualizan componentes. La presentación recomienda aprobar software antes de instalarlo, restringir privilegios, evaluar las solicitudes de cambio, documentar las modificaciones, probar sus efectos y supervisar los resultados. Un

cambio no autorizado o mal planificado puede convertirse en una vulnerabilidad.
Finalmente, se describen controles específicos contra el malware: filtrado de tráfico, inspección de correos y archivos, uso de software antimalware, actualización de sistemas, gestión de incidentes y recuperación. Se presentan controles preventivos, de detección y correctivos, junto con recomendaciones de gestión de identidades y acceso. El sentido de la validación es verificar de forma repetida que las protecciones funcionen frente a amenazas cambiantes.

Tema 5. Protección y control de acceso

El quinto tema explica cómo determinar quién puede utilizar recursos de un sistema y qué operaciones está autorizado a realizar. La presentación emplea el modelo IAAA: identificación, autenticación, autorización y rendición de cuentas. Identificar consiste en declarar una identidad; autenticar significa comprobarla; autorizar implica establecer los permisos sobre un recurso; y rendir cuentas consiste en registrar acciones y asociarlas con sujetos responsables.
La autenticación puede apoyarse en tres tipos de factores: algo que una persona sabe (contraseña o PIN), algo que posee (tarjeta, token o dispositivo) y algo que es (rasgos biométricos). La presentación recomienda combinar factores para lograr una verificación más robusta, y analiza fortalezas y debilidades de cada alternativa. También trata la gestión de contraseñas, destacando la importancia de credenciales largas, difíciles de adivinar y de evitar su reutilización.
Entre los mecanismos asociados al acceso remoto aparecen las redes privadas virtuales (VPN), que protegen las comunicaciones de usuarios externos mediante túneles; y el inicio de sesión único (SSO), que permite acceder a diferentes recursos mediante una autenticación centralizada. Ambos mecanismos requieren una implementación adecuada, porque su utilidad no elimina la necesidad de revisar permisos y supervisar cuentas.
El control de acceso se representa por medio de una matriz que relaciona sujetos, objetos y permisos. Las filas corresponden a usuarios o procesos y las columnas a recursos. La presentación explica dos formas de organizar dicha información: listas de control de acceso (ACL), asociadas a cada objeto, y listas de capacidades, que describen los recursos y acciones disponibles para un sujeto. Estos modelos ayudan a aplicar el principio de mínimo privilegio.
En el entorno de redes, se recomiendan separación o segmentación de sistemas críticos, supervisión del tráfico, control de conexiones y uso de herramientas que permitan identificar problemas. La presentación menciona herramientas de análisis y monitoreo, como Wireshark y Microsoft Network Monitor, para observar paquetes y facilitar diagnósticos. También enfatiza la revisión periódica de derechos de acceso, especialmente tras cambios de funciones o salidas de empleados.
La privacidad y protección de los datos personales ocupan otra parte importante del tema. El material menciona la información de identificación personal (IIP), los avisos de privacidad, la minimización de datos, su eliminación segura, la anonimización y la seudonimización. Anonimizar implica eliminar los vínculos que permitirían identificar a una persona; seudonimizar implica tratar los datos de manera que su atribución a una persona requiera información adicional conservada por separado.
La prevención de fugas de datos (DLP) se presenta como un conjunto de medidas para identificar información sensible y evitar su divulgación no autorizada. Se relaciona con clasificación, control de circulación de archivos, seguridad de dispositivos propios y protección de datos en servicios externos y en la nube.
Para favorecer la recuperación frente a fallos o ataques, la presentación explica las copias de seguridad completas, diferenciales e incrementales. La copia completa incluye todos los datos seleccionados; la diferencial contiene los cambios acumulados desde la última copia completa; y la incremental incluye los cambios desde la última copia de cualquier tipo. La estrategia debe incorporar periodicidad, retención, almacenamiento separado, protección y pruebas de restauración.

El bloque concluye con la externalización de servicios y la computación en la nube. Se presentan características como autoservicio bajo demanda, acceso amplio a la red, agrupación de recursos, elasticidad y servicio medido. Los modelos tratados son infraestructura como servicio (IaaS), plataforma como servicio (PaaS), software como servicio (SaaS) y comunicaciones unificadas como servicio (UCaaS). La protección depende de comprender qué gestiona el proveedor y qué debe asegurar la organización usuaria.

Tema 6. Modelos formales de protección

En la presentación, este apartado contiene dos diapositivas. La primera compara los niveles de integración y gestión de distintos servicios en la nube, mostrando capas como aplicaciones, datos, tiempo de ejecución, middleware, sistema operativo, virtualización, servidores, almacenamiento y redes. El gráfico ilustra que la distribución de responsabilidades varía entre infraestructura tradicional, IaaS, PaaS, UCaaS y SaaS.

En un entorno de infraestructura tradicional, la organización administra prácticamente todas las capas. En los servicios de nube se transfieren algunas funciones al proveedor según el modelo contratado, pero ello no significa que el cliente pierda sus obligaciones sobre la información y los accesos. La correcta asignación de responsabilidades es, por lo tanto, una decisión central de protección.

La segunda diapositiva reproduce un proceso de gestión de riesgos basado en ISO/IEC 27005. Su secuencia incluye establecimiento del contexto, identificación de riesgos, análisis, valoración, tratamiento, aceptación, comunicación y consulta, así como seguimiento y revisión. Este enfoque permite fundamentar la selección de medidas de seguridad en decisiones sistemáticas y periódicas.

Es importante no atribuir al archivo el desarrollo de modelos formales clásicos que no aparecen en estas dos diapositivas. En el contexto del material, la protección formal se presenta sobre todo como asignación estructurada de responsabilidades y gestión metódica de riesgos.

5. Conclusiones

- La seguridad de la información es un proceso continuo que combina tecnología, personas, procedimientos y decisiones de gestión. Su finalidad principal es preservar la confidencialidad, integridad y disponibilidad de los recursos informáticos.
- El análisis de amenazas y vulnerabilidades permite anticipar riesgos asociados con accesos no autorizados. Los controles preventivos, de detección y correctivos deben seleccionarse considerando tanto la probabilidad de un incidente como su impacto.
- Los ataques internos y externos requieren estrategias complementarias. El software malicioso, el ransomware, la ingeniería social, las fugas de datos y los ataques de denegación de servicio muestran que la seguridad no puede depender de una sola herramienta.
- La seguridad debe incorporarse desde el diseño de las aplicaciones y mantenerse mediante revisiones, criptografía, gestión de claves, análisis de vulnerabilidades, controles antimalware y procedimientos para administrar cambios.
- La identificación, autenticación, autorización y rendición de cuentas son esenciales para limitar el uso indebido de información. A estas medidas deben sumarse protección de datos personales, políticas de respaldo y controles para servicios externos.
- En la computación en la nube, la responsabilidad de proteger cada capa del sistema varía según el servicio contratado. El proceso sistemático de gestión de riesgos ayuda a ordenar decisiones, asignar responsabilidades y mejorar los controles.